



EKOPARTY MIAMI

# THREAT INTELLIGENCE 101

---

*From Reactive to  
Predictive Approach*

**David Pérez**

CTI · Advisor

22 de junio de 2026

# About.ME

|   |                                                                                               |
|---|-----------------------------------------------------------------------------------------------|
| A | Fanático de Star Wars                                                                         |
| B | Temas que sigo: Threat Intelligence - Ransomware.                                             |
| C | Roles en los que me desempeñé:                                                                |
| D | SOC Analyst (L1, L2)                                                                          |
| E | Phishing Analyst                                                                              |
| F | Threat Intelligence – Incident Response                                                       |
| G | Inteligencia Criminal (Reunión de Información) –<br>Contra Inteligencia (Estado de Argentina) |
| H | Hobbies: Drones, Impresión 3D, Cultivo mis Hongos<br>(Comestibles), Destilo mi GIN.           |



Certified Incident  
Responder



Certified Threat  
Hunter Professional



|    |                                                                 |     |
|----|-----------------------------------------------------------------|-----|
| 01 | ¿Por qué CTI hoy? · Mito vs realidad del adversario             | 2'  |
| 02 | Fundamentos · Pipeline · Ciclo · PIRs                           | 4'  |
| 03 | Fuentes de Threat Intelligence                                  | 3'  |
| 04 | Frameworks (Kill Chain · Diamond · ATT&CK · Pirámide del Dolor) | 11' |
| 05 | De reactivo a predictivo · Madurez CTI · Métricas               | 4'  |
| 06 | Case Study: "Puedes correr, pero no puedes esconderte"          | 5'  |
| 07 | Cierre, takeaways y Q&A                                         | 1'  |

# ¿Por qué CTI hoy?

El terreno se aceleró. La asimetría no.

## EL TERRENO SE ACELERÓ

**62 min**

Breakout time promedio de eCrime — el más rápido: 2 min 7 s. (CrowdStrike 2024)

**75 %**

De las intrusiones son malware-free: credenciales válidas y herramientas legítimas.

**\$4.88M**

Costo promedio global de un breach — récord histórico. (IBM 2024)

**10 días**

Dwell time mediano: el atacante vive adentro antes de ser detectado. (Mandiant 2024)

## LA ASIMETRÍA NO CAMBIÓ

### ATACANTE

Elige momento, vector y objetivo.

### ATACANTE

Una puerta abierta alcanza.

### ATACANTE

Itera barato, falla sin costo.

### ATACANTE

Conoce a su víctima.

### DEFENSOR

Cubre todo, todo el tiempo.

### DEFENSOR

Tiene que cerrar todas.

### DEFENSOR

Cada falso positivo cuesta horas.

### DEFENSOR

¿Conoce a su adversario?

# ¿Qué NO es CTI?

Tres mitos que matamos antes de seguir.

## NO es un feed de IOCs

Un feed sin contexto es ruido caro.  
La inteligencia empieza cuando preguntás ¿esto me afecta?

## NO es un dashboard de actores

Conocer los nombres no defiende.  
Conocer los TTPs que usan contra la industria, y dónde te tocan, sí.

## NO es atribución

Saber quién atacó es un nice-to-have. Saber cómo te van a atacar y, qué decisión tenés que tomar mañana, eso es CTI.



CTI es un proceso para responder preguntas que cambian decisiones. Si la inteligencia que damos, no puede traducirse en una decisión, es mala.

## BLOQUE 02 · FUNDAMENTOS

***Data, Information, Intelligence — y los marcos para convertirla en decisión.***

# Data → Information → Intelligence

INTELLIGENCE

*Análisis accionable para un decisor.*

OPORTUNA

RELEVANTE

PRECISA

ACCIONABLE

INFORMATION

*Datos procesados con contexto.*

DATA

*Hashes, IPs, logs crudos sin contexto.*

Me estas diciendo que un feed de IOCs es CTI?

Dilo una vez mas, te desafio

## Cyber Threat Intelligence

*Cyber Threat Intelligence es el proceso de recolectar, procesar, analizar y diseminar información sobre adversarios — para que los defensores tomen decisiones informadas.*

**SANS Institute · FOR578: Cyber Threat Intelligence**

# Known / Unknown: El modelo Rumsfeld

## KNOWN KNOWNS

01

*Realidad operativa*

**Lo que sabemos que sabemos.**

### ESCENARIO

*IT usa ScreenConnect autorizado. LockBit, Akira y Medusa abusan AnyDesk, Atera y SimpleHelp — firmados, allowlisteados, invisibles para tu EDR.*

**Aca vive el SOC reactivo.**

## KNOWN UNKNOWNNS

02

*Incertidumbre estratégica*

**Sabemos que hay cosas que no sabemos.**

### ESCENARIO

*Infostealers (Lumma, Redline) capturan tokens de RMM cada día. La cookie de ScreenConnect de tu técnico puede estar en venta en Russian Market ahora mismo. No hackean — compran la llave.*

**Aca viven los PIRs y el threat hunting.**

## UNKNOWN UNKNOWNNS

03

*Cisne negro cibernético*

**Lo que no sabemos que no sabemos.**

### ESCENARIO

*Zero-day en el servidor RMM. (CVE-2024-1708/1709 en ScreenConnect, CVSS 10.0): bypass de auth, admins fantasma sin alertas. Black Basta y LockBit ya lo explotaban antes del parche.*

**Aca vive la inteligencia anticipatoria.**

**El objetivo de CTI: mover lo máximo posible de Unknown a Known — y aceptar lo que no podés mover.**

# Visualizando los Knowns / Unknowns

El mismo marco del slide anterior — aplicado al modelado de adversarios (Attack Trees).



El Secretario de Defensa de EE.UU., durante la Guerra en Irak, popularizó un marco de gestión de riesgos basado en lo que sabemos y lo que ignoramos. El modelo se convirtió en una herramienta esencial para analistas de inteligencia para categorizar riesgos y priorizar la recolección de datos.

## Matriz de Conocimiento en Attack Trees

Known-Knowns aplicados a la construcción de árboles de ataque



“En la construcción de Attack Trees, los Known Knowns se representan con líneas sólidas, los Known Unknowns con líneas discontinuas (postulados) y los Unknown Unknowns son las áreas que requieren investigación adicional o pruebas de hipótesis.”

# Tipos de CTI: mismo dato, distinto consumidor

## ESTRATÉGICA

### CONSUMIDOR

**CISO · Board · CEO**

### CONTENIDO

Tendencias, riesgos geopolíticos, decisiones de inversión.

### HORIZONTE

**Meses → años**

## OPERACIONAL

### CONSUMIDOR

**SOC Manager · IR Lead**

### CONTENIDO

Campañas activas, actores apuntando al sector, IOCs y TTPs.

### HORIZONTE

**Semanas → meses**

## TÁCTICA

### CONSUMIDOR

**SOC analyst · Threat hunter**

### CONTENIDO

Reglas Sigma/YARA, IOCs concretos, hunts puntuales.

### HORIZONTE

**Horas → días**

# Mismo análisis, 3 entregables

*El problema no es la data, es el storytelling .*

## EJECUTIVO

### FORMATO

**1 página · 1 gráfico**

### PREGUNTA QUE LE INTERESA

*"¿Qué amenaza nuestro negocio y cuánto cuesta mitigarla?"*

## MANAGER

### FORMATO

**1 informe · 5 puntos clave**

### PREGUNTA QUE LE INTERESA

*Esto va a implicar un cambio en algun Software o Hardware que debamos sacar de produccion?*

## ESPECIALISTA

### FORMATO

**Detalle técnico completo**

### PREGUNTA QUE LE INTERESA

*"Dame las TTPs y los IOCs para automatizar."*

**Traduce lo técnico al idioma del negocio:** A un CEO o a una junta directiva no les importan los hashes, las direcciones IP o las llaves de registro alteradas. El storytelling convierte un aburrido "detectamos el malware X" en un impactante "un grupo cibercriminal está intentando robar nuestra base de datos de clientes para extorsionarnos".

# Ciclo de inteligencia · 6 fases

1

1

## Dirección

Definir PIRs y necesidades del decisor.

6

Feedback

Dirección

Recolección

2

3

## Procesamiento

Normalizar, deduplicar, enriquecer.

4

## Análisis

Correlación, hipótesis, atribución.

5

Diseminación

Análisis

Procesamiento

3

6

## Feedback

Medir si cambió alguna decisión. El paso que casi todos saltan.

4

Ciclo de  
Inteligencia

# PIR (Priority Intelligence Requirements)

## QUÉ ES UN PIR

*La pregunta concreta que el decisor necesita que CTI responda para tomar una acción defensiva específica.*

### QUIÉN LO ESCRIBE

El decisor: CISO, SOC Manager, IR Lead. No el analista.

### QUIÉN LO RESPONDE

El equipo de CTI.

### SU ROL

Filtra el ruido del feed infinito para que llegue solo lo que importa.



### MAL PIR

*"¿Cuáles son los nuevos hackeos en internet?" — vago, infinito, no dispara nada.*



Los PIRs son las preguntas que el negocio necesita que CTI responda. Sin PIR, todo lo demás es ruido.

# PIRs · Priority Intelligence Requirements

*Las preguntas concretas del decisor que CTI tiene que responder.*

|             |                                                                                      |
|-------------|--------------------------------------------------------------------------------------|
| ESTRATÉGICO | <i>¿Qué actores con motivación geopolítica están apuntando a fintech en LATAM?</i>   |
| OPERACIONAL | <i>¿Cuáles son las TTPs activas de ransomware contra retail los últimos 90 días?</i> |
| TÁCTICO     | <i>¿Qué indicadores de C2 de Lumma Stealer se reportaron esta semana?</i>            |

**No podés defender todo, en todos lados, todo el tiempo. PIRs = dónde mirar primero.  
Si tu reporte no responde un PIR, no es inteligencia. Es información que sobra.**

## BLOQUE 03 · FUENTES DE THREAT INTELLIGENCE

***Rapid fire: 5 fuentes + cómo se gradan + VIBEINT.***

# OSINT · HUMINT · SIGINT · GEOINT · CHIS

|               |                                                                                                                                      |
|---------------|--------------------------------------------------------------------------------------------------------------------------------------|
| <b>OSINT</b>  | Open Source: foros, redes, leaks, certificate transparency, Shodan/Censys/GreyNoise.                                                 |
| <b>HUMINT</b> | Human: informantes, investigadores en foros, fuentes de la industria.                                                                |
| <b>SIGINT</b> | Signals: telemetría de red, PDNS pasivo, NetFlow. (Government Communications Headquarters (GCHQ).                                    |
| <b>GEOINT</b> | Explotación y análisis de imágenes y datos geoespaciales                                                                             |
| <b>CHIS</b>   | Covert Human Intelligence Sources: Persona que mantiene una relación (personal o de otro tipo) con otra persona de forma encubierta. |

# Admiralty Code: Cómo calificar las fuentes e información

## Confiabilidad de la fuente

|          |                           |
|----------|---------------------------|
| <b>A</b> | Completamente confiable   |
| <b>B</b> | Usualmente confiable      |
| <b>C</b> | Razonablemente confiable  |
| <b>D</b> | No usualmente confiable   |
| <b>E</b> | No confiable              |
| <b>F</b> | Confiabilidad desconocida |

## Credibilidad de la información

|          |                              |
|----------|------------------------------|
| <b>1</b> | Confirmada por otras fuentes |
| <b>2</b> | Probablemente cierta         |
| <b>3</b> | Posiblemente cierta          |
| <b>4</b> | Cierta dudosa                |
| <b>5</b> | Improbable                   |
| <b>6</b> | Veracidad no determinable    |

*Una fuente "A1" es confiable y confirmada · una "F6" aporta ruido, no inteligencia.*

El sistema nace en la **Royal Navy británica**, en el Naval Intelligence Division (NID). Lo utilizan OTAN, FBI, US Army, Europol, INTERPOL, fuerzas policiales de inteligencia en todo el mundo, y unidades de CTI de empresas.

## Bonus track: La sexta fuente que nadie cita

*Hay una sexta fuente. No está en ningún manual. La uso todos los días.*

# VIBEINT

*Información obtenida de un presentimiento o de la intuición — usualmente basada en experiencia previa. Mayormente no verificada, ocasionalmente lleva a un hallazgo real.*

## BLOQUE 04 · FRAMEWORKS

*Kill Chain · Diamond · MITRE ATT&CK · Pirámide del Dolor.*

# Los 4 frameworks no compiten — se componen

## CYBER KILL CHAIN

*Lockheed Martin · 2011*

Las 7 fases de un ataque.

## DIAMOND MODEL

*Caltagirone et al. · 2013*

Adversary · Capability · Infrastructure · Victim.

## MITRE ATT&CK

*MITRE · 2013 → presente*

Catálogo de TTPs. Lingua franca de la industria.

## PIRÁMIDE DEL DOLOR

*David Bianco · 2013*

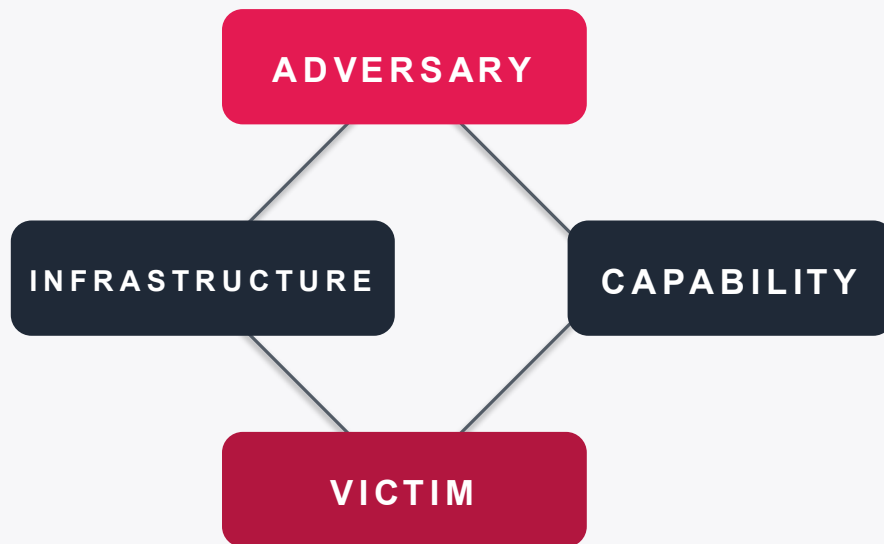
Qué duele al atacante: IOCs vs TTPs.

# Cyber Kill Chain - 7 fases (Lockheed Martin, 2011)



- **Estructura lineal y secuencial:** Asume que los ataques avanzan de forma Ordenada y predecible.
- **Enfoque orientado a perímetro y malware:** Fue diseñado principalmente para amenazas externas.
- **Falta de granularidad:** Solo identifica fases de alto nivel sin detallar técnicas, procedimientos ni comportamientos específicos del adversario (TTPs).

# Diamond Model · 4 vértices que cuentan toda la historia



**Cada evento de intrusión = 4 vértices.**

## **Adversary**

— quién (intención, atribución).

## **Capability**

— malware, exploits, técnicas.

## **Infrastructure**

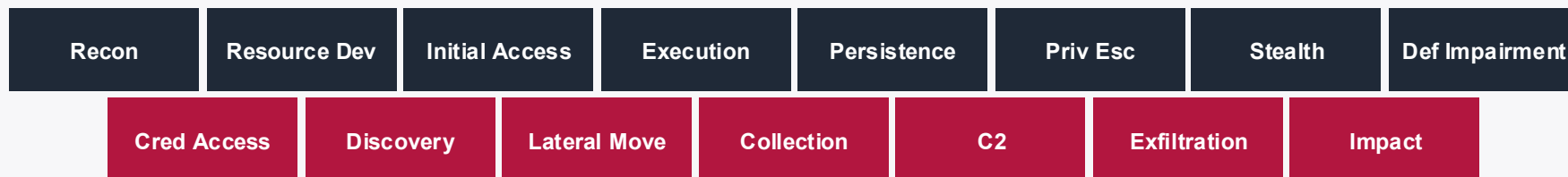
— C2, dominios, certificados.

## **Victim**

— quién recibe el ataque.

# MITRE ATT&CK · la lengua franca de la industria

15 Tácticas · 222 Técnicas · 475 Sub-técnicas · **v19 (oct 2025)**



*v19 (oct 2025) partió Defense Evasion en Stealth (escondarse) + Defense Impairment (romper la defensa).*

## Detection Engineering

Mapear reglas Sigma/SIEM a técnicas para medir cobertura real.

## Threat Hunting

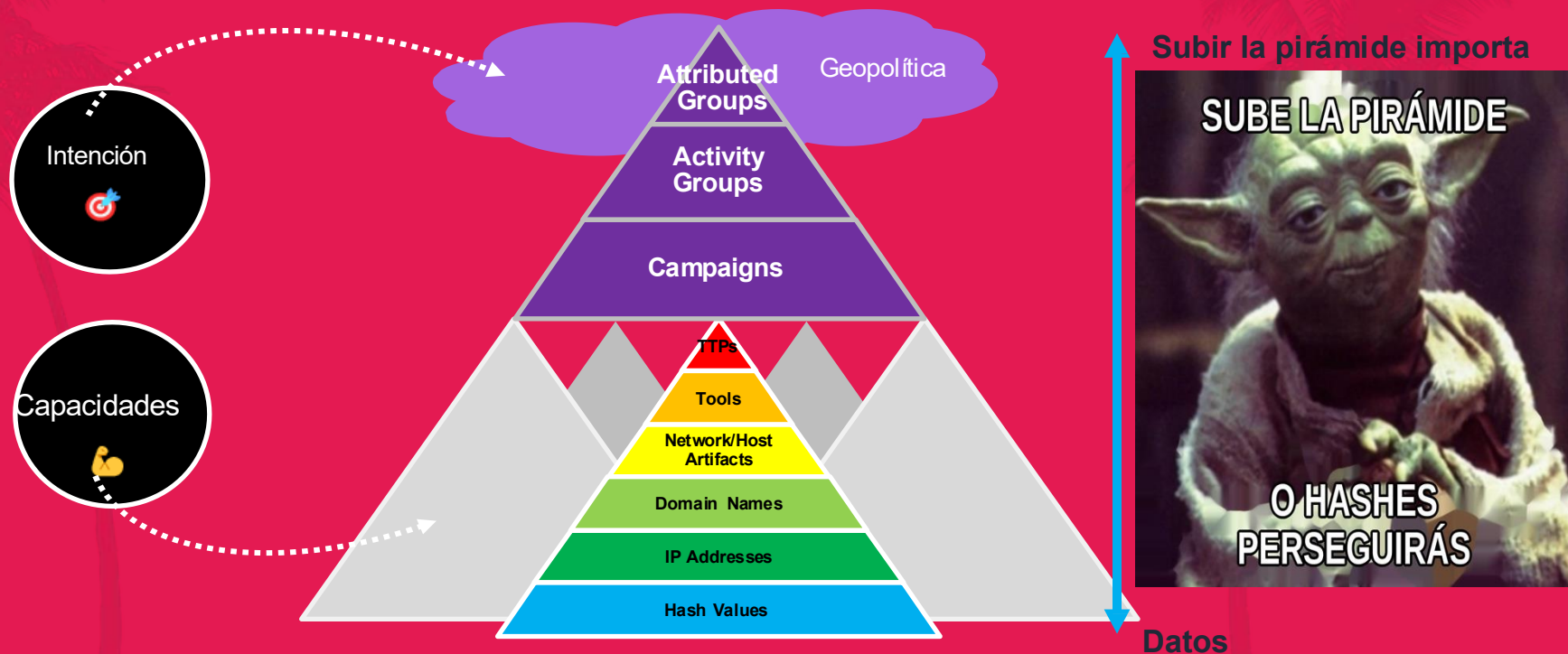
Generar hipótesis sobre técnicas no detectadas.

## Purple Teaming

Emular adversarios reales mapeados a técnicas concretas.

**Advertencia: mapear todo a ATT&CK no garantiza cobertura defensiva real.**

# Hablar con los stakeholders en el idioma correcto



Extendiendo la pirámide del Dolor

## BLOQUE 05 · DE REACTIVO A PREDICTIVO

*PIRs · F3EAD · Attack Trees · threat-informed defense.*

# Madurez CTI · las 3 etapas del shift

Desde el subtítulo de la charla: **"From Reactive to Predictive Approach"**. No es marketing — es una ruta de madurez.

| REACTIVO                                    | PROACTIVO                                  | PREDICTIVO                                       |
|---------------------------------------------|--------------------------------------------|--------------------------------------------------|
| <b><i>Apago incendios.</i></b>              | <b><i>Cazo amenazas.</i></b>               | <b><i>Anticipo movimientos.</i></b>              |
| TRIGGER<br>La alerta llegó al SIEM.         | TRIGGER<br>Hipótesis del threat hunter.    | TRIGGER<br>PIRs + inteligencia estratégica.      |
| PREGUNTA<br>¿Qué pasó? ¿Cómo lo contenemos? | PREGUNTA<br>¿Qué no estamos viendo?        | PREGUNTA<br>¿Qué va a pasarnos en 30/60/90 días? |
| INDICADOR<br>Hashes · IPs · Dominios        | INDICADOR<br>TTPs · comportamientos        | INDICADOR<br>Campañas · actores · geopolítica    |
| MENTALIDAD<br>Forense post-mortem           | MENTALIDAD<br>Hipótesis-driven             | MENTALIDAD<br>Anticipatory · F3EAD               |
| MÉTRICA<br>MTTR (Mean Time To Respond)      | MÉTRICA<br>Cobertura de detección (ATT&CK) | MÉTRICA<br>Tiempo a la decisión defensiva        |

***Pasar de Reactivo a Predictivo no se compra — se construye etapa por etapa.***

# Por qué la TI tradicional se queda corta

Asume que la inteligencia llega antes del ataque. En la práctica, casi nunca pasa.

## TI TRADICIONAL

Reactiva · post-mortem · histórica

- Asume que la inteligencia llega antes del ataque
- CVSS dice cuán mala podría ser. EPSS dice cuán probable es que la exploten esta semana.
- IOCs históricos: ya pasó
- Reformula disclosures públicos de terceros
- Equipos ahogados en alertas que no responden el ¿nos afecta hoy?

## MUNDO REAL

Weaponization en horas · escaneo en minutos

- Plazos de explotación en horas tras disclosure
- PoC público acelera la weaponization
- Internet entero escaneado en minutos
- Atacantes chainan vulns + creds + misconfigs
- Vuln 7.0 explotada activamente; 9.8 puede no usarse

La severidad externa decía 7.0. La interna era 11.

# ¿Cómo medís que CTI funciona?

Cuatro métricas que le hablan al CISO, no al SOC.

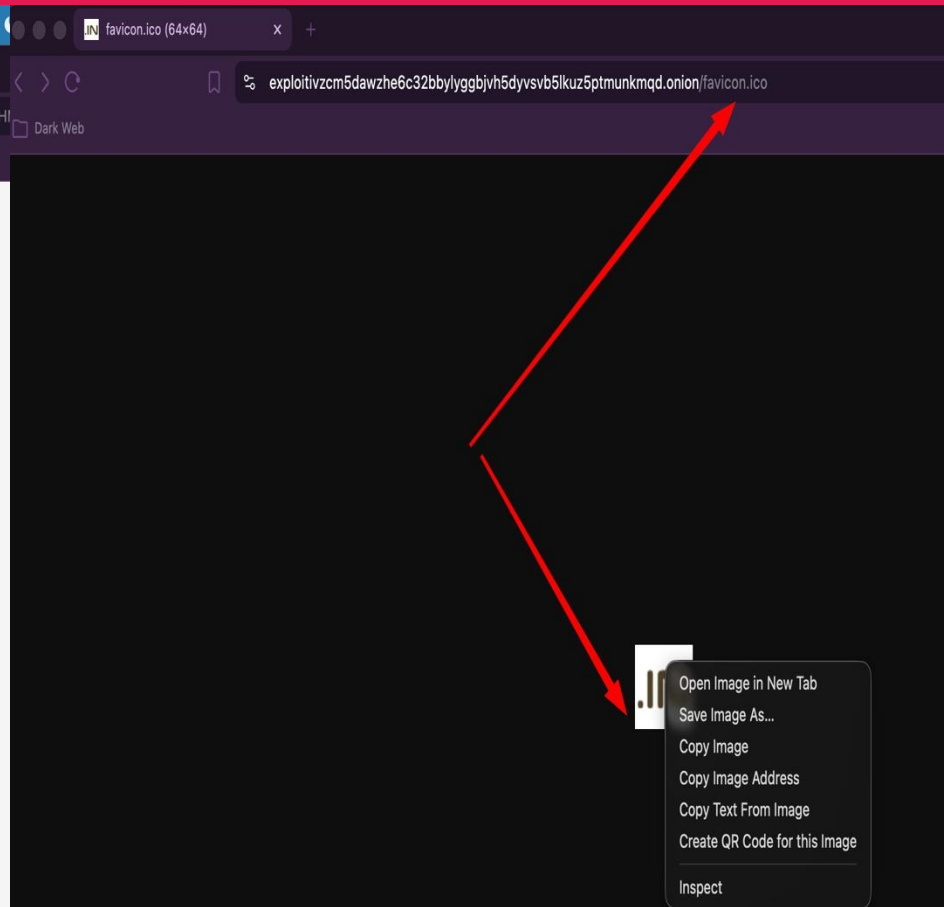
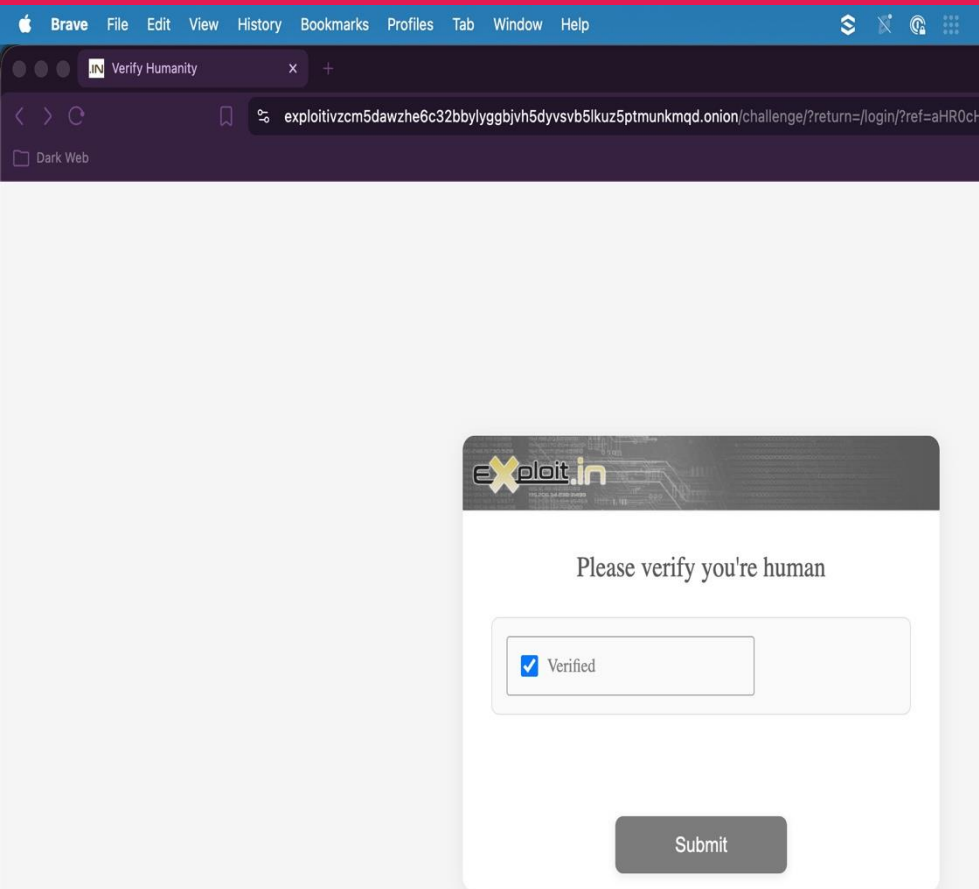
| TTPS                                                                                          | PIR                                                                                     | DEC                                                                                      | COV                                                                                       |
|-----------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------|
| <b>Time to detect<br/>TTP shift</b>                                                           | <b>% PIRs<br/>respondidos en SLA</b>                                                    | <b>Decisiones cambiadas<br/>por CTI</b>                                                  | <b>Cobertura ATT&amp;CK<br/>activos críticos</b>                                          |
| Días entre que el adversario cambia técnica y vos lo detectás. Idealmente, semanas, no meses. | Preguntas del decisor cerradas a tiempo. Si está abajo del 80%, CTI no está siendo CTI. | Reportes que dispararon acción concreta: parchar, bloquear, contratar, escalar al board. | % de técnicas con detección o prevención sobre las crown jewels. No sobre toda la matriz. |

CTI debe poder cambiar reglas de negocio en una organizacion. Ese es su valor agregado.

## BLOQUE 06: PUEDES CORRER...

*...pero no puedes esconderte. Hunting Infrastructure for newbies..*

# Un servicio en la Dark Web que se cree 100% anónimo, deja artefactos.



# Un servicio en la Dark Web que se cree 100% anónimo, deja artefactos.

The screenshot shows a web browser window with the address bar displaying 'favicon-hash.kmsec.uk'. The website has a dark theme and is titled 'Favicon hash generator'. Below the title, it says 'Get the favicon hash of a website's favicon for Shodan hunting'. There are two main sections: 'Retrieve from URL' and 'Upload file'. The 'Retrieve from URL' section has a text input field containing 'https://www.google.com/favicon.ico' and a blue button labeled 'Hash from URL'. The 'Upload file' section has a 'File browser' label, a 'Choose File' button, and a file name 'favicon.ico'. Below this is a blue button labeled 'Hash from file'. Under the 'Hash from file' button, it says 'Result for file:' followed by two rows of results: 'favicon\_hash' with the value '932673402' and 'md5' with the value 'b8c71f831e9cb09e879122267af9200a'. At the bottom, there are three buttons: 'Search Shodan', 'Search VirusTotal', and 'Search Censys'.

**Favicon hash generator**

Get the favicon hash of a website's favicon for Shodan hunting

**Retrieve from URL**  
Favicon URL

**Hash from URL**

**Upload file**  
File browser

**Choose File** favicon.ico

**Hash from file**

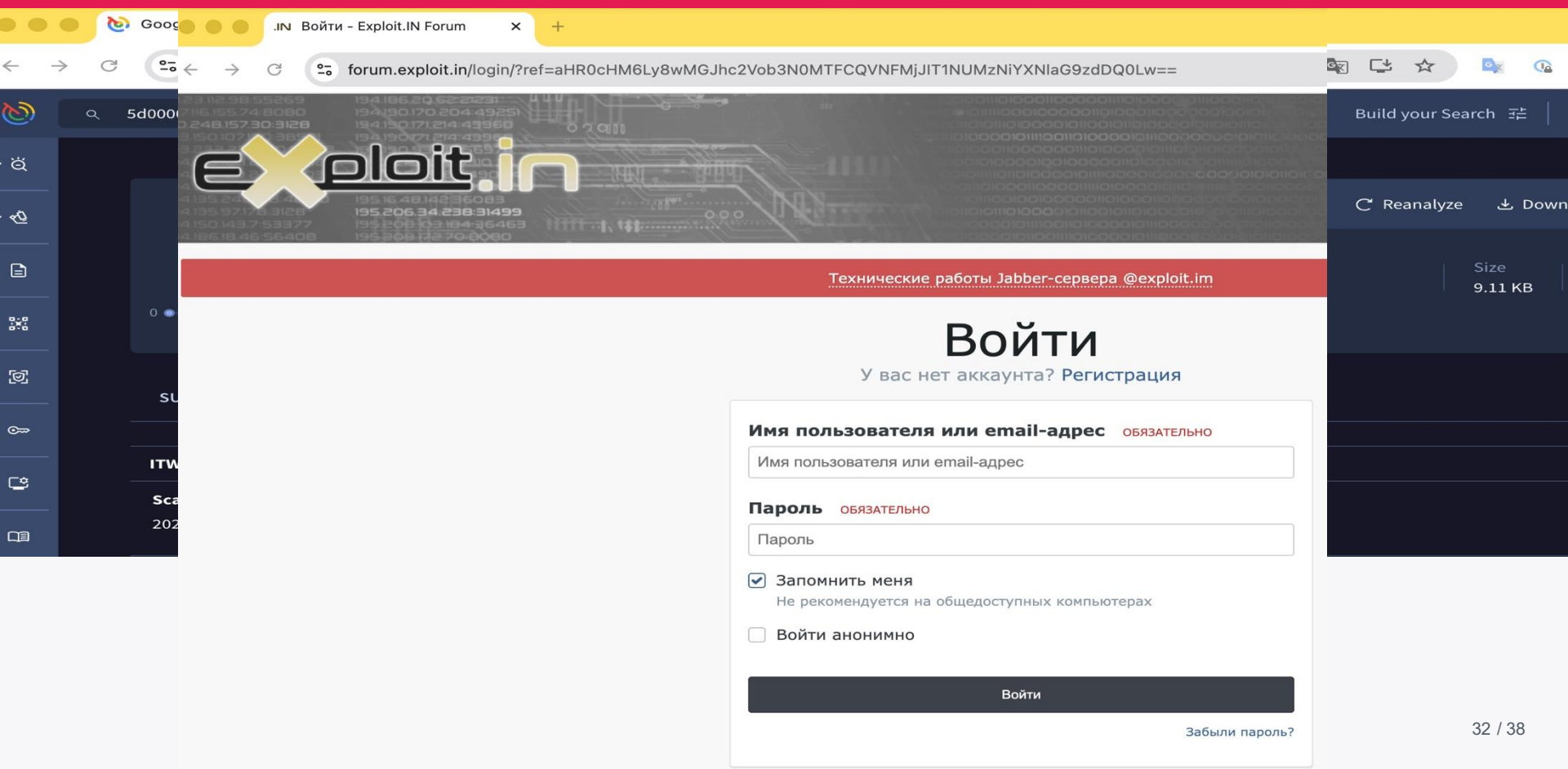
Result for file:

|              |                                  |
|--------------|----------------------------------|
| favicon_hash | 932673402                        |
| md5          | b8c71f831e9cb09e879122267af9200a |

**Search Shodan** **Search VirusTotal** **Search Censys**

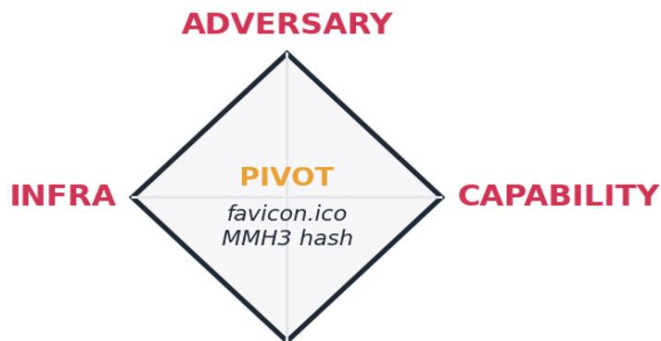
Se carga el Archivo en [favicon-hash.kmsec.uk](https://favicon-hash.kmsec.uk) y se aplica el algoritmo **MurmurHash3**, se obtiene un HASH específico también MD5

# Un servicio en la Dark Web que se cree 100% anónimo, deja artefactos.



# Aplicando Diamond + ATT&CK al caso

## DIAMOND MODEL



**ADV.** EXPLOIT.IN ops · Moscow, RU

**INFRA.** forum.exploit.in (NameSilo)  
89.39.149.156 · Nginx · + .onion

**CAP.** Foro · Tor HS · marketplace

**VICT.** N/A directo (downstream)

## MITRE ATT&CK v19

### TA0042 · Resource Development

**T1583.001** **Domains**  
forum.exploit.in · NameSilo

**T1583.004** **Server**  
89.39.149.156

**T1588** **Capability**  
marketplace exploits/access

### TA0011 · Command and Control

**T1090.003** **Multi-hop Proxy**  
mirror .onion (Tor)

**T1071** **App Layer Protocol**  
HTTP/HTTPS · Nginx

Pivot favicon.ico (MMH3) en Shodan/Censys → mismo hash en .onion y clearweb → confirmación de cluster

# Por qué hablamos de RMMs: los números

Living off the Land ya no es excepción. Es la norma operativa del cibercrimen.

**+277%**

Aumento YoY en abuso de  
RMM (2025 vs 2024)

**24%**

1 de cada 4 incidentes  
involucra un RMM

**59.4%**

Ransomware que entra por  
external remote access

**51.3%**

Concentración de Big Four:  
Akira · Medusa · Qilin ·  
RansomHub

**"Los atacantes continúan apoyándose en la eficiencia operativa — iniciando sesión en lugar de irrumpir, robando datos en lugar de cifrarlos, y explotando herramientas confiables en lugar de vulnerabilidades complejas."**

— Ismael Valenzuela · VP of Labs · Arctic Wolf

# Living off the Land · RMMs utilizadas por adversarios

## TOP TIER · las más citadas en incidentes recientes

### ScreenConnect

ConnectWise Control

El más citado de todos en incidentes.

### SimpleHelp

Medusa · DragonForce

Protagonista en campañas de ransomware.

### AnyDesk

LockBit

Habitual para post-compromiso.

## VISTAS EN CAMPAÑAS · APTs, ransomware, vishing

### Atera

MuddyWater · Royal · BianLian · ALPHV

### NetSupport Mgr

RAT legacy · Top 4 Red Canary

### PDQ Connect/Deploy

Pivot para desplegar otros RMMs

BeyondTrust

LogMeIn

GoTo Resolve

N-able

Splashtop

FleetDeck

Ms Quick Assist



“Bloquear el acceso a las RMMs  
tu debes.”

# 3 cosas que te llevás

01

**CTI = proceso, no herramienta.**

*Empieza por escribir tus PIRs. Sin PIRs, no hay inteligencia.*

02

**Apuntá a la cima de la pirámide.**

*Cambiar un hash es trivial. Cambiar un TTP es meses de re-trabajo para el adversario.*

03

**El adversario también deja artefactos.**

*Pivoting + framework + tiempo = atribución. El anonimato perfecto no existe.*



# ¡Gracias!

*Preguntas, dudas, debate.*

---

# Referencias:

Verizon Data Breach Report: <https://www.verizon.com/business/resources/reports/2024-dbir-data-breach-investigations-report.pdf>

State of Vulnerability Response: <https://es.scribd.com/document/1019779413/1730403607-State-of-Vulnerability-Response-Ponemon>

Keys to the Kingdom: <https://techcommunity.microsoft.com/blog/microsoftsecurityexperts/keys-to-the-kingdom-rmm-exploits-enabling-human-operated-intrusions-in-2024%E2%80%934410903>

Understanding the Risks of Remote Monitoring and Management Tools: <https://arcticwolf.com/resources/blog/understanding-the-risks-of-remote-monitoring-and-management-tools/>

Cyber Kill Chains: Strategies & Tactics: [https://www.splunk.com/en\\_us/blog/learn/cyber-kill-chains.html](https://www.splunk.com/en_us/blog/learn/cyber-kill-chains.html)

Daisy-Chaining Rogue RMM Tools: <https://www.huntress.com/blog/daisy-chaining-rogue-rmm-tools>

Proyectos - Tools: <https://lolrmm.io> - <https://favicon-hash.kmsec.uk>

Autores: @gertjanbruggink